

SAVUNAN TARAFTA OLMAK

[Kaynak](#)

İÇERİK

1. Defensive Security (Savunma Odaklı Güvenlik) Kavramı ve Temelleri
2. Hedef Altyapıyı ve Çevreyi Anlamak (Understanding Your Environment)
3. Savunma Ortamının Tahkimatı ve Defansif Zihniyet (Defending Your Environment)

Defensive Security (Savunma Odaklı Güvenlik) Kavramı ve Temelleri

Savunma Mimarisinin Çekirdek Yapısı

Defensive Security (Savunma Odaklı Güvenlik), bir sistemde tam olarak neyin korunması gerektiğini analiz etme, potansiyel saldırıları proaktif olarak engelleme (prevent), saldırı anında anormallikleri tespit etme (detect) ve ihlalin yaratacağı teknik tahribatı en aza indirme (mitigate) süreçlerinin bütünüdür. Savunma uzmanlarının temel operasyonel amacı, ağ ve sistem altyapısı üzerinde mutlak bir görünürlük (visibility) elde ederek zayıf noktaları yamamaktır. Bir altyapıda neyin çalıştığını ve trafiğin nasıl aktığını kör noktalar olmadan izleyemiyorsanız, o sistemi savunmanız teknik olarak imkansızdır.

Bu defansif yapı, bilgi güvenliğinin omurgasını oluşturan **CIA Triad** (Confidentiality - Gizlilik, Integrity - Bütünlük, Availability - Erişilebilirlik: Verinin yetkisiz erişimden korunması, değiştirilmemesi ve ihtiyaç anında erişilebilir olması prensibi) ilkeleriyle doğrudan entegre şekilde inşa edilir. Savunmacının nihai hedefi yalnızca saldırıları sınırdan bloklamak değil; aynı zamanda kaçınılmaz güvenlik ihlallerine (incidents) karşı önceden prosedürel olarak hazırlıklı olmak ve olay anında sistemin **Availability** (Erişilebilirlik) durumunu çökertmeden operasyonu sürdürebilmektir.

ÖNEMLİ: Defansif güvenlik stratejisinde "Prevention" (Önleme) ideal ve arzulanan ilk katmandır ancak tek başına asla yeterli değildir. Kusursuz ve aşılamaz bir güvenlik mimarisi matematiksel olarak kurulamayacağı için, modern savunma konsepti "Detection" (Sistemdeki olağandışı hareketleri loglar üzerinden anında tespit etme) ve "Mitigation" (Zararının yanal hareketini engelleme ve izole etme) mekanizmalarına hayati bir önem atfeder.

Blue Team (Mavi Takım) ve Saldırgan Zihniyetini Tersine Mühendislik İle Anlamak

Siber güvenlikte kurumların savunma hattını oluşturan uzmanlar genellikle **Blue Team** (Mavi Takım: Kurumların bilgi işlem altyapısını izleyen, savunan, siber tehdit avcılığı yapan ve olaylara müdahale eden güvenlik ekibi) olarak adlandırılır. Bir **Blue Team** analistinin sahada

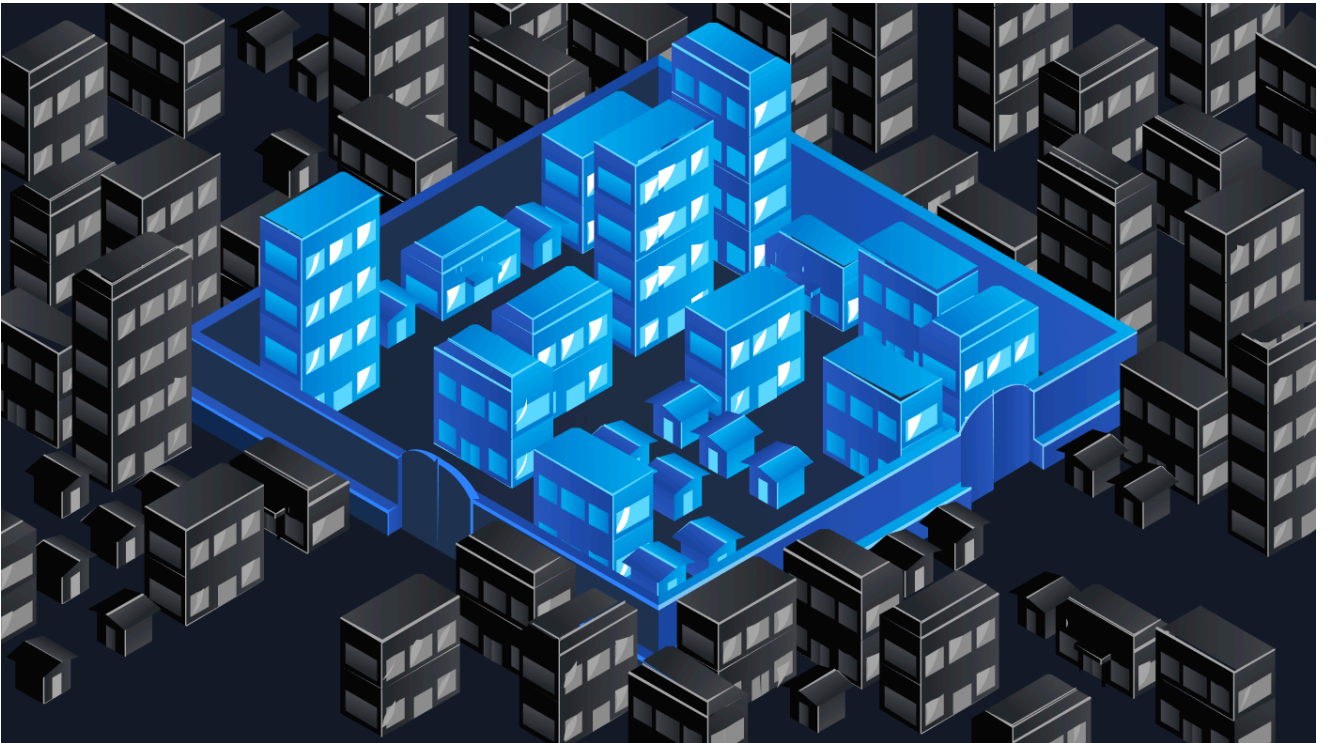
başarılı olabilmesi için, **Ethical Hacker**'ların (Etik Hacker: Kötü niyetli aktörlerle aynı istismar tekniklerini kullanarak sistemlerdeki zafiyetleri kurumun lehine tespit eden güvenlik uzmanı) veya doğrudan tehdit aktörlerinin zihniyetini dekode etmesi zorunludur.

Bu gereklilik şu mantık zincirine dayanır: Bir saldırganın hangi servisleri hedef alacağını, saldırı vektörlerinin (attack vectors) hangi adımlarla ilerleyeceğini (örneğin; keşif, sızma, hak yükseltme, kalıcılık sağlama) ve nihai hedeflerini anlamadan proaktif bir kural yazılamaz. Bu nedenle savunma analistleri, öncelikle kurumun **kritik altyapısını (critical infrastructure)** sınıflandırır. Hangi sunucunun düşmesinin kurumu felç edeceğini belirler ve saldırganın bu sunucuya giden yolda kullanabileceği rotaları analiz ederek savunma katmanlarını doğrudan bu hedeflerin üzerine konumlandırır. Özetle etkili bir savunma; sadece pasif bir izleme işi değil, saldırganın adımlarını öngörerek sistemi önceden tahkim etme sanatıdır.

Hedef Altyapıyı ve Çevreyi Anlamak (Understanding Your Environment)

Görünürlük (Visibility) ve Altyapı Analizi

Bir siber güvenlik analistinin sahada karşılaştığı ilk ve en kritik kural şudur: **Kör olduğunuz bir altyapıyı savunamazsınız.** Kurumun ağında bulunan sunucuların, son kullanıcı cihazlarının, açık portların ve veri akış yönlerinin tam bir haritasına sahip değilseniz, uygulayacağınız güvenlik politikaları havada kalacaktır. Bu durum, bir şehrin sınırlarını ve kritik binalarını bilmeden o şehri savunmaya çalışmaya benzer. Savunmacıların öncelikli görevi, çevrelerinde (environment) neyin var olduğunu ve bu bileşenlerin birbirleriyle olan ağ veya servis seviyesindeki entegrasyonlarını saptamaktır.



Gerçek dünya senaryolarında temel savunma soruları ve bunların teknik karşılıkları şu şekilde mantıklandırılır:

- **Neyi Koruyoruz? (Asset Inventory):** Korunacak varlıklar basit kullanıcı cihazları (workstation), kritik veri tabanları veya dışarıya açık web sunucuları olabilir. Her varlığın kritiklik seviyesi (criticality) farklıdır ve uygulanacak güvenlik politikasının sıklığını bu belirler.
- **Koruduğumuz Varlığı Görebiliyor muyuz? (Visibility):** Sistemdeki kameraların yerini ağ trafiğini izleyen araçlar (örn: IDS/IPS sistemleri), sistem logları ve güvenlik uyarıları alır. Eğer bir sunucuda işlem kaydı (logging) aktif değilse, o sunucu ele geçirildiğinde geçmişe dönük hiçbir analitik veri elde edilemez.
- **Şüpheli Davranışın Karşılığı Nedir? (Anomaly Detection):** Kilitli bir kapıyı zorlamak fiziksel bir ihlal girişimi iken, siber dünyada aynı kaynağın (IP adresinin) saniyeler içinde yüzlerce kez başarısız giriş denemesi yapması **Brute-Force** (Kaba Kuvvet: Hedef sisteme erişmek için otomatik araçlarla sürekli parola veya anahtar denenmesi) saldırısına işaret eder. Olağandışı IP adreslerinden gelen bağlantılar da benzer şekilde bir **SIEM** (Security Information and Event Management) kuralını tetiklemelidir.
- **Tehdit Nasıl Durdurulur? (Containment):** Polis barikatlarının yerini siber dünyada **Firewall** (Güvenlik Duvarı) kuralları ve **IP blocking** (Zararlı IP adresinin ağa erişiminin kesilmesi) mekanizmaları alır.

Savunma Odaklı Güvenliğin Temel Operasyonel Fazları

Bir ağın topolojisini ve içindeki varlıkları anladıktan sonra, **Blue Team** analistinin süreçleri, endüstri standardı olan aşağıdaki 5 temel güvenlik konsepti etrafında şekillenir. Bu konseptler birbirini izleyen ve besleyen bir döngü oluşturur:

1. Prevention (Önleme - Proaktif Savunma) Saldırıları sistem sınırlarından içeri girmeden durdurmayı hedefleyen ilk katmandır. **Firewall** kurallarının sıkılaştırılması, imza tabanlı **Antivirus / EDR** (Endpoint Detection and Response) çözümlerinin dağıtılması ve sistemlerdeki zafiyetlerin yamalanması (Patch Management) bu aşamadadır. *Neden yapıyoruz?* Bilinen zafiyetleri (CVE'ler) kapatarak saldırganın en düşük eforla sisteme sızmasını (low-hanging fruit) engellemek için.

2. Detection (Tespit - Anomali Avcılığı) Önleme mekanizmalarını aşan (örneğin bir Zero-Day zafiyeti veya ortalama saldırısı ile) tehditleri ağ içinde yakalama sürecidir. Sistem loglarının toplanıp korelasyona sokulması, ağ trafiğindeki anormal paket boyutlarının incelenmesi ve alarm mekanizmalarının devreye girmesi bu aşamada gerçekleşir. Zafiyet aşıldığında ikinci savunma hattınız tespit kabiliyetinizdir.

3. Mitigation (Hafifletme ve İzolasyon) Bir ihlal (incident) doğrulandığında, saldırının ağ üzerindeki yanal hareketini (Lateral Movement) engellemek için alınan acil aksiyonlardır. *Örnek Senaryo:* Bir kullanıcının hesabı ele geçirildiğinde (Compromised Account), o hesabın Active Directory üzerindeki yetkilerinin anında askıya alınması veya zararlı yazılım bulaşmış bir makinenin ağdan izole edilerek **VLAN** (Sanal Yerel Ağ) dışına çıkarılması bir Mitigation adımıdır. Amaç, yangının diğer sunuculara sıçramasını önlemektir.

4. Analysis (Analiz ve Adli Bilişim) Saldırganın izole edilmesinin ardından "Nasıl girdiler?", "Hangi dosyaları değiştirdiler?", "Veri dışarı sızdırıldı mı (Data Exfiltration)?" sorularının yanıtlandığı derinlemesine teknik inceleme safhasıdır. Olay müdahale (Incident Response) ekipleri logları, bellek dökümlerini (memory dumps) ve ağ pcap (packet capture) dosyalarını analiz ederek saldırının kök nedenini (Root Cause Analysis) bulur.

5. Response and Improvement (Müdahale ve İyileştirme) Analiz sonucunda elde edilen veriler ışığında sistemin güvenli bir duruma geri döndürülmesi (Recovery) ve güvenlik mimarisindeki boşlukların kapatılmasıdır. "Bir daha aynı yolla içeri girmemeleri için hangi IDS kuralını yazmalıyım?" sorusunun cevabı burada hayata geçirilir.

ÖNEMLİ: Savunma uzmanlarının yetki ve sorumluluk alanı (**Scope**), tüm interneti değil; yalnızca kurumun veya müşterinin yasal mülkiyetinde olan varlıkları kapsar. Scope dışına çıkıp aktif bir saldırgana karşı saldırı düzenlemek (Hack-back) etik ve yasal kuralların dışındadır.

Kritik Altyapı Bileşenleri ve Roller



Savunulacak bir ağın anatomisi genellikle belirli spesifik sistemlerden oluşur. Bu sistemlerin her birinin ağ topolojisindeki konumu, uygulanacak güvenlik sıklılığını belirler:

- **Employee Devices (Çalışan Cihazları / Endpoints):** Kullanıcıların şirket kaynaklarına eriştiği bilgisayarlar veya mobil cihazlardır. Siber güvenlikte en zayıf halka genellikle insandır; bu nedenle bu cihazlar ortalama (Phishing) ve zararlı yazılım (Malware) saldırılarının bir numaralı hedefidir.
- **Web Server (Web Sunucusu):** Şirketin dış dünyaya (internete) sunduğu hizmetleri (uygulamalar, siteler) barındırır. Doğrudan dışarıya açık oldukları için genellikle **DMZ** (Demilitarized Zone: Dış ağ ile iç ağ arasında tampon bölge görevi gören izole edilmiş ağ

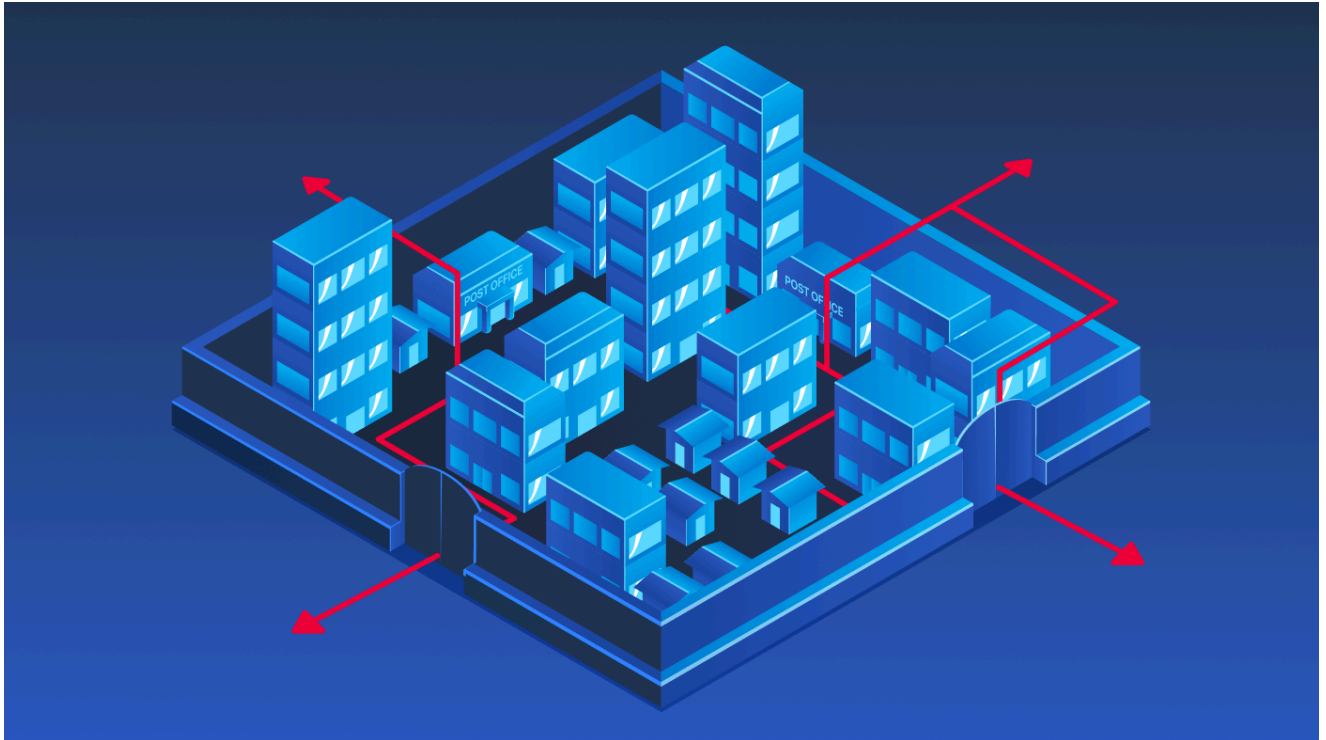
alanı) adı verilen özel bir ağ segmentinde tutulurlar. Hedeflenen saldırılar genellikle SQL Injection veya Cross-Site Scripting (XSS) gibi web uygulama zafiyetleridir.

- **Mail Server (E-posta Sunucusu):** Organizasyonun iç ve dış e-posta trafiğini (SMTP, IMAP, POP3 protokolleri üzerinden) yönetir. Kurumsal veri sızıntılarının ve oltalama bağlantılarının ana geçiş noktasıdır.
- **Firewall (Güvenlik Duvarı):** Şirketin iç ağı (LAN) ile kontrol edilemeyen dış ağ (WAN / Internet) arasındaki sınır kapısıdır. Paket filtreleme (Stateful Inspection) yaparak hangi IP ve Port'ların içeri girebileceğine veya dışarı çıkabileceğine karar veren ana güvenlik omurgasıdır.
- **Internet (İnternet / Untrusted Zone):** Organizasyonun kontrolü dışındaki her şeydir. Savunma zihniyetinde internet her zaman "%100 Güvenilmez (Untrusted)" olarak kabul edilir ve bu alandan gelen tüm trafik varsayılan olarak şüpheli sayılmalıdır (Zero Trust yaklaşımı).

Savunma Ortamının Tahkimatı ve Defansif Zihniyet (Defending Your Environment)

Savunmacı Zihniyeti (The Defender Mindset) ve Saldırı Zinciri

Sadece ortamınızdaki varlıkların (asset) bir listesine sahip olmak, o sistemi savunmak için yeterli değildir. Etkili bir **Blue Team** (Mavi Takım) analistinin başarısı, sistemleri birbirinden bağımsız izole adalar olarak görmeyi bırakıp, altyapıyı birbirine bağlı bir ekosistem olarak analiz edebilmesine bağlıdır.



Gerçek dünyada bir **Threat Actor** (Tehdit Aktörü: Kötü niyetli saldırgan veya grup), nadiren doğrudan nihai hedefe (örneğin ana veritabanına) saldırır. Bunun yerine, direncin en düşük olduğu noktadan içeri sızar ve hedefine ulaşana kadar sistemler arasında bir zincir reaksiyonu yaratır.

ÖNEMLİ: Bir saldırının anatomisi genellikle şu şekilde ilerler: Saldırgan, bir çalışanın cihazına (Workstation) zararlı bir e-posta ekiyle (Malicious Attachment) sızar ve **Initial Access** (İlk Erişim) sağlar. Bu cihaz üzerinden hafızadaki parolaları çalarak (Credential Harvesting) yetkilerini yükseltir. Elde ettiği bu geçerli kimlik bilgileriyle ağ içinde **Pivoting / Lateral Movement** (Sıçrama / Yanal Hareket: Ele geçirilen bir sistem üzerinden, ağdaki diğer hedeflere doğru ilerleme eylemi) gerçekleştirerek e-posta sunucusuna veya hassas verilerin bulunduğu **Database Server**'a (Veritabanı Sunucusu) ulaşır.

Bir savunmacı olarak bilmeniz gereken en kritik nokta şudur: **Saldırganın attığı her adım, sizin için bir tespit ve engelleme fırsatıdır.** Saldırı zincirinin (Attack Chain) herhangi bir halkasında uygulayacağınız doğru bir güvenlik önlemi, tüm operasyonu çökertebilir.

Kritik Savunma Prensipleri (Key Defender Principles)

Bir altyapıyı proaktif olarak savunmak için operasyonel süreçlerinize aşağıdaki dört temel prensibi entegre etmeniz zorunludur:

- **Threat Anticipation (Tehdit Öngörüsü ve Modelleme):** Sorumlu olduğunuz sistemleri gözden geçirip "Ya olursa?" (What if?) sorusunu sormalısınız. Saldırganın nihai hedefine ulaşmak için hangi yolları izleyebileceğini (Attack Paths) gerçekçi bir şekilde simüle etmeli ve savunma katmanlarını bu muhtemel rotalar üzerine kurmalısınız.
- **Attack Awareness (Saldırı Farkındalığı):** Siber saldırılar kaotik değildir; genellikle belirli, tanınabilir aşamaları takip ederler. Bir savunmacı olarak **Cyber Kill Chain** veya **MITRE ATT&CK** gibi endüstri standardı çerçeveleri (framework) inceleyerek saldırganların yaygın olarak kullandığı taktik, teknik ve prosedürleri (TTPs) ezbere bilmelisiniz.
- **Risk Prioritization (Risk Önceliklendirmesi):** Ağınızdaki her cihazın güvenlik değeri veya taşıdığı risk eşit değildir. Bir stajyerin bilgisayarını ile şirketin finansal verilerini tutan bir sunucuya aynı eforu harcamazsınız. Yüksek değerli (High-value) hedefleri belirleyip güvenlik bütçenizi ve izleme (Monitoring) odak noktanızı bu varlıklara kaydırmalısınız.
- **Continuous Adaptation (Sürekli Adaptasyon):** Savunma, "kur ve unut" (set-and-forget) tarzı bir işlem değildir. Yeni **Zero-Day** (Sıfırıncı Gün: Üreticisi tarafından henüz yaması yayınlanmamış, bilinmeyen zafiyet) açıkları ortaya çıkar, saldırganların teknikleri evrimleşir. Savunma mimariniz bu dinamik tehdit manzarasına ayak uyduracak şekilde sürekli güncellenmeli ve test edilmelidir.

Derinlemesine Savunma (Defense in Depth) ve Uygulama Yöntemleri

Altyapıyı bir şehre benzettiğimiz senaryoda, tek bir devasa duvar (sınır güvenliği) inşa etmek yerine, içeri giren bir tehdidin hareket alanını kısıtlayacak iç güvenlik mekanizmaları (**Defense in Depth** - Derinlemesine Savunma) kurmak zorundayız. Hedef altyapı bileşenleri üzerindeki potansiyel riskler ve bunlara karşı uygulanacak teknik savunma mekanizmaları şunlardır:

1. Employee Devices (Çalışan Uç Noktaları / Endpoints)

- **Zafiyet / Risk:** Çalışanların ortalama (Phishing) bağlantılarına tıklaması veya yetkisiz/zararlı yazılımlar indirmesi. Uç noktalar, ağa sızmak için en çok kullanılan kapılardır.
- **Savunma Stratejisi (Mitigation):** İmzaya ve davranışsal analize dayalı **Antivirus / EDR** (Endpoint Detection and Response: Uç noktalardaki anormallikleri tespit edip müdahale eden sistem) çözümleri devreye alınmalıdır. İşletim sistemi ve üçüncü parti uygulamalar için katı bir **Patch Management** (Yama Yönetimi) politikası uygulanarak bilinen güvenlik açıkları (CVE'ler) kapatılmalıdır.

2. Web Server (Web Sunucusu)

- **Zafiyet / Risk:** Web sunucuları internete açık olmak zorundadır. Bu durum onları SQL Injection, XSS veya Dizin Gezinme (Directory Traversal) gibi web tabanlı saldırıların doğrudan hedefi yapar.
- **Savunma Stratejisi (Mitigation):** Sunucuya gelen trafik bir **WAF** (Web Application Firewall: Web uygulamalarına yönelik HTTP/HTTPS saldırılarını filtreleyen güvenlik duvarı) arkasına alınmalıdır. İletişim kesinlikle şifreli (TLS/SSL) olmalı ve sunucu üzerinde sadece uygulamanın çalışması için elzem olan portlar (Örn: 443) açık bırakılıp geri kalan tüm portlar dışarıdan erişime kapatılmalıdır (Principle of Least Privilege).

3. Mail Server (E-posta Sunucusu)

- **Zafiyet / Risk:** Sosyal mühendislik harikası, aldatıcı e-postaların ve **Malware** (Zararlı Yazılım) barındıran eklerin kurumsal ağa giriş yaptığı ana terminaldir.
- **Savunma Stratejisi (Mitigation):** Gelen kutusuna ulaşmadan önce e-postaları filtreleyen gelişmiş **Spam Filter** ve **Email Security Gateway** çözümleri kullanılmalıdır. Gelen ekler (attachments) son kullanıcıya ulaşmadan önce izole bir **Sandbox** (Kum havuzu: Dosyaların güvenli bir ortamda çalıştırılarak zararlı olup olmadıklarının analiz edildiği sistem) ortamında çalıştırılarak davranış analizi yapılmalıdır.

4. Firewall (Güvenlik Duvarı)

- **Zafiyet / Risk:** İnternet üzerindeki botnet'lerin veya saldırganların kurum iç ağına (LAN) yetkisiz erişim sağlamaya veya iç ağdan dışarıya veri sızdırmaya (Data Exfiltration) çalışması.
- **Savunma Stratejisi (Mitigation):** **Ingress/Egress Filtering** (Gelen ve giden trafik filtrelemesi) yapan sıkı **Firewall Kuralları (ACL - Access Control Lists)** yazılmalıdır. Bilinen zararlı IP adresleri, **IoC** (Indicator of Compromise: Uzlaşma Göstergesi, bir saldırının varlığını kanıtlayan IP, domain veya hash gibi veriler) veri tabanları kullanılarak ağ sınırında bloklanmalıdır.

5. The Outside Internet (İnternet / Dış Ağ)

- **Zafiyet / Risk:** Organizasyonun hiçbir kontrolünün olmadığı, sürekli tarama (Scanning) ve otonom saldırıların geldiği kaotik bölgedir.
- **Savunma Stratejisi (Mitigation):** Varsayılan kural her zaman "**Default Deny**" (Açıkça izin verilmeyen her türlü trafiği reddet) olmalıdır. Dışarıdan içeriye (Inbound) doğru başlatılan hiçbir bağlantı, spesifik bir iş ihtiyacı ve kuralı yoksa kabul edilmemelidir. Gelen trafik sadece izlenmekle kalmamalı, anormalliklere karşı **IDS/IPS** (Saldırı Tespit ve Önleme Sistemleri) ile sürekli olarak analiz edilmelidir.